

Canadian Interoperable FHIR Health Server

Revised Software Development Life Cycle (SDLC)
Addendum and Production-Readiness Extension

Version 1.1 · August 2026

Purpose. This document supplements the existing Version 1.0 SDLC. It retains the original Java 17, Spring Boot, HAPI FHIR R4, PostgreSQL, Keycloak, PS-CA, and SMART on FHIR direction, while adding the governance, safety, semantic, federation, operational, and testing capabilities required for a realistic Canadian interprovincial interoperability implementation.

This addendum is intended to be incorporated after the original SDLC's Phase 8 and treated as a required extension to the project baseline.

1. Executive Summary

The original SDLC establishes a technically credible FHIR-server prototype. Its focus on structured FHIR resources, PS-CA summaries, OAuth2/SMART on FHIR, audit logging, and Canadian deployment is a sound starting point. The project must, however, address more than API exposure and storage in order to safely exchange personal health information across provincial and organizational boundaries.

Canadian interoperability depends on three linked layers: technical interoperability (systems can exchange data), semantic interoperability (systems interpret it consistently), and organizational/legal interoperability (systems are authorized, governed, and operationally capable of sharing it). This addendum adds requirements for all three layers.

The solution must not claim to create one central, unconditional “single source of truth.” Instead, it will create a **trusted federated longitudinal view** that preserves each source organization’s authority, provenance, data freshness, terminology context, and jurisdiction-specific access policies.

Key production-readiness gaps closed by this addendum

- Cross-provincial patient identity and duplicate-record governance.
- Consent-aware, purpose-based, and relationship-aware authorization.
- Exact versioning and conformance for PS-CA, CA Core+, CACDI, and terminology artifacts.
- Canadian terminology management, mapping, source-code preservation, and data-quality controls.
- Federated provincial-gateway design, trust management, resilient retrieval, and partial-response handling.
- Clinical provenance, data freshness, reconciliation, correction, and conflict-management requirements.
- Privacy, clinical safety, Indigenous data governance, French-language, accessibility, and operational requirements.
- Production DevSecOps, disaster recovery, monitoring, incident response, and benefits realization.

2. Revised Problem and Solution

2.1 Revised problem statement

Canadian healthcare information is distributed across provincial, territorial, regional, and organizational systems that use different identifiers, terminology, privacy policies, data models, vendors, and exchange mechanisms. Although many organizations possess electronic records, authorized clinicians often cannot obtain a complete, current, machine-readable patient summary when care crosses organizational or provincial boundaries.

The resulting gap is not simply the absence of electronic records. It is the absence of a trusted federated interoperability capability that combines common Canadian health-data content, versioned FHIR profiles, shared terminology, cross-jurisdiction identity resolution, consent-aware authorization, provenance and freshness indicators, secure gateway federation, clinical workflow integration, and operational accountability.

Static PDFs, faxes, and proprietary formats prevent reliable programmatic search and interpretation. Incomplete or stale medication, allergy, laboratory, diagnostic, and condition information can contribute to repeated testing, medication discrepancies, delayed clinical decision-making, and administrative burden.

2.2 Revised solution statement

Build a secure Canadian FHIR interoperability platform using Java 17, Spring Boot, HAPI FHIR R4, PostgreSQL, Keycloak, a Canadian terminology service, and jurisdiction-specific gateway adapters. The platform will enable authorized clinicians and systems to discover, retrieve, validate, and exchange a priority patient summary while preserving source authority, patient consent, provenance, and clinical safety.

3. Scope, Governance, and Success

3.1 Initial scope

Area	Version 1.1 scope
Jurisdictions	Ontario and British Columbia pilot; expansion-ready design for other provinces and territories
Clinical priorities	Identity, conditions, allergies, medication information, immunizations, labs, diagnostic reports, procedures, encounters, providers and organizations
Interoperability baseline	FHIR R4; pinned PS-CA and CA Core+ releases; CACDI Version 2 alignment; approved Canadian terminology artifacts
Exchange model	Federated query and retrieval with explicit source provenance; bounded caching; no silent central replacement of source records
Out of scope for v1	Full EMR replacement, autonomous clinical AI, billing/claims replacement, native mobile applications

3.2 Expanded stakeholder model

- Provincial health ministries, digital-health agencies, and regional health authorities.
- Hospitals, emergency departments, primary-care practices, pharmacies, laboratories, imaging providers, long-term care, home care, and mental-health services.
- Patients, caregivers, patient advocacy groups, and accessibility representatives.
- First Nations, Inuit, and Métis representatives and applicable Indigenous data-governance bodies.
- Privacy commissioners, legal counsel, cybersecurity teams, clinical informaticians, health information managers, and professional colleges.
- Canada Health Infoway, CIHI, FHIR/terminology communities, EMR vendors, cloud providers, identity providers, and provincial gateway operators.

3.3 Measurable success criteria

Outcome	Initial measurable target
Profile conformance	At least 95% of required patient-summary elements valid against the pinned profile baseline for conformance test data
Identity safety	100% deterministic test identities resolve correctly; no automatic merge below approved confidence threshold
Authorization audit	100% of protected cross-jurisdiction requests contain requester, organization, purpose, consent decision, timestamp, and correlation identifier
Provenance	100% of returned clinical facts expose source and freshness metadata
Reliability	Local service availability target 99.9%; remote gateway success and partial response are measured separately
Clinical usability	Clinical pilot acceptance criteria include time-to-summary, completeness, clarity of stale data, and medication/allergy reconciliation workflow
Privacy and security	No PHI in application logs, public endpoints, test fixtures, or telemetry; all releases pass required security and privacy gates

4. Standards and Semantic Baseline

4.1 Version control requirement

The project shall maintain a formal interoperability baseline document. Every deployment must identify the exact FHIR R4 version, PS-CA implementation-guide release, CA Core+ release, CACDI version, terminology package versions, validation packages, profile URLs, and approved deviations. “PS-CA compliant” is not an adequate claim unless supported by reproducible validation and conformance evidence.

4.2 Required standards alignment

Component	Requirement
FHIR	HL7 FHIR R4 with documented REST, search, operation, history, Bundle, OperationOutcome, and CapabilityStatement support
Patient summary	Implement the pinned PS-CA profiles, required sections, cardinalities, constraints, extensions, and terminology bindings
Core exchange	Use the pinned CA Core+ profile and terminology baseline
Canadian content	Map and validate required data elements against CACDI Version 2 and its logical data model
Terminology	Use applicable Canadian SNOMED CT, pCLOCD/LOINC, Canadian Clinical Drug Data Set, and Canadian value sets; preserve original source coding
Interoperability quality	Use automated profile, terminology, and gateway contract validation in CI/CD

4.3 Terminology service requirements

- Provide a FHIR terminology service supporting CodeSystem, ValueSet, ConceptMap, NamingSystem, validation, lookup, translation, and expansion.
- Preserve original source system, code, display, and version alongside normalized Canadian concepts.
- Record mapping method, mapping confidence, mapping status, and terminology release version.
- Flag unmapped, deprecated, ambiguous, or invalid codes; do not silently substitute clinical meanings.
- Support English and French display values where provided by the applicable terminology artifacts.
- Run terminology regression tests when a terminology package is upgraded.

5. Privacy, Governance, and Consent

5.1 Compliance workstream

PIPEDA, Ontario PHIPA, BC PIPA, data residency, and encryption are necessary but not sufficient. Before production use, the project shall complete a privacy impact assessment, threat and risk assessment, data-flow inventory, role analysis, and contracts or data-sharing agreements for each participating jurisdiction and gateway.

Control area	Required design decision
Legal roles	Identify health information custodians, information managers/service providers, source organizations, and gateway responsibilities
Disclosure authority	Document legal basis, purpose of use, consent assumptions, and exceptions for each cross-jurisdiction flow

Control area	Required design decision
Patient rights	Support access, correction, restrictions where applicable, complaints, and response workflows
Breach response	Define detection, containment, assessment, notification, evidence preservation, and post-incident review
Data residency	Document storage, backup, logs, telemetry, support access, key management, and subcontractor locations
Indigenous governance	Engage applicable Indigenous partners early; do not assume provincial consent rules alone resolve data-governance obligations
Language/accessibility	Provide bilingual and accessible patient and clinician communication requirements

5.2 Consent-aware access model

SMART on FHIR scopes provide application-level authorization but do not by themselves establish a clinician's right to access a cross-jurisdiction record. The platform shall enforce layered authorization: authenticated identity, practitioner status, organization membership, patient relationship where required, declared purpose of use, patient consent policy, resource-level policy, and jurisdiction-specific rules.

- Support FHIR Consent, Practitioner, PractitionerRole, Organization, Provenance, and AuditEvent resources or equivalent governed representations.
- Require a correlation ID and access context for every interprovincial request.
- Support emergency break-glass access only with reason capture, enhanced audit, alerting, retrospective review, and policy-defined expiry.
- Deny access when authorization or policy evaluation cannot be completed for a sensitive cross-jurisdiction read or write.
- Use least-privilege resource scopes rather than unrestricted patient/* .read or user/* .write defaults.

6. Patient Identity, Provenance, and Data Quality

6.1 Cross-provincial identity service

A provincial health number must be treated as a jurisdiction-scoped identifier, not as a pan-Canadian universal key. Name and date of birth alone must never constitute definitive proof of identity.

Identity component	Requirement
Multiple identifiers	Store identifier value, assigning system URI, identifier type, jurisdiction, status, period, source, and verification date
Deterministic matching	Use trusted identifiers where a jurisdiction permits and confirms their use
Probabilistic matching	Generate candidate matches from approved demographic attributes; return confidence and rationale
Human adjudication	Require review for uncertain, conflicting, or high-impact matches
Merge governance	Maintain merge/unmerge history, reviewer identity, evidence, timestamps, and correction workflow
Safety rule	Never silently merge patients on a low-confidence probabilistic score

6.2 Provenance and freshness

Audit logging records who accessed data; provenance describes where a clinical fact originated and how it changed. Both are required.

- Capture source organization, source system, source resource ID, author/recorder where known, effective time, recorded time, last synchronization time, and transformation history.
- Expose whether a result was obtained live, retrieved from a cache, imported, reconciled, or manually entered.
- Display data freshness and partial-response status to clinical users.
- Represent conflicting data without silently overwriting the source record.
- Preserve source clinical codes and normalized terminology mappings.

6.3 Data lifecycle

- Define retention schedules by data class and jurisdiction.
- Use versioning, soft deletion, correction history, legal-hold handling, and source-correction propagation.
- Set resource-specific cache expiry; never present stale cached clinical data as current truth.
- Encrypt backups, test restoration regularly, and define secure destruction procedures.
- Use de-identified or synthetic data outside production unless a formally approved exception exists.

7. Federated Architecture and FHIR Design

7.1 Target architecture

The platform should operate as a federated broker and clinical-summary service rather than a universal central repository. Provincial or organizational systems remain authoritative for their source records. The platform discovers capabilities, resolves identity under policy, performs authorized queries, validates and normalizes returned resources, preserves provenance, and renders a transparent longitudinal view.

Core components: API gateway; SMART authorization service; policy and consent engine; patient identity service; gateway registry and adapters; terminology service; FHIR resource store and indexing layer; provenance/audit service; caching service with safety rules; clinical summary service; operational monitoring; and incident/security telemetry.

7.2 Provincial gateway adapter contract

- Capability discovery: FHIR version, profiles, supported operations, terminology, authentication, rate limit, and maintenance windows.
- Patient discovery: deterministic and candidate-match responses with confidence, no implicit merge.
- Summary retrieval: request context includes requester, organization, purpose, consent decision, patient reference, and correlation ID.
- Response normalization: profile validation, terminology validation, provenance capture, partial-response and freshness labeling.
- Resilience: timeout, bounded retry, circuit breaker, idempotency, duplicate suppression, and gateway-health monitoring.
- Operations: support contacts, gateway-specific SLA, test endpoint, incident route, and version-deprecation policy.

7.3 FHIR resources required beyond v1.0

Domain	Required resources
Clinical	Condition, AllergyIntolerance, MedicationRequest, MedicationStatement, MedicationDispense, MedicationAdministration, Immunization, Observation, DiagnosticReport, ImagingStudy, Procedure, Encounter, ServiceRequest
Care context	CarePlan, CareTeam, Practitioner, PractitionerRole, Organization, Location
Documents and summaries	Composition, Bundle, DocumentReference, Binary with strict policy controls
Trust and governance	Consent, Provenance, AuditEvent, Endpoint, OperationOutcome
Platform behavior	CapabilityStatement, resource versioning, _history, ETags, conditional operations, security labels, source identifiers

7.4 Storage design

Use a hybrid storage model: canonical FHIR JSONB resources for fidelity and versioning, plus normalized indexed projections for required searches and operational reporting. Every persisted resource must retain resource type, logical ID, version ID, source system, source resource ID, patient linkage, profile URL/version, last updated time, security labels, provenance reference, and raw FHIR JSON.

8. Security and Resilience Requirements

8.1 Security controls

- TLS 1.3 for external traffic; mutual TLS for gateway-to-gateway connections where agreed.
- Strong issuer, audience, signature, expiry, and key-rotation validation for JWTs.
- Managed secrets, hardware-backed or managed key storage, scheduled rotation, and separate credentials per environment.
- Network segmentation, private endpoints, least privilege, database access controls, and administrative MFA.
- Dependency, container, infrastructure, and secret scanning; SBOM generation and signed deployable artifacts.
- Tamper-evident audit storage, centralized monitoring, alerting, and security incident playbooks.
- No PHI in logs, trace payloads, error reports, or lower-environment datasets.

8.2 Cache and outage safety

Redis may cache discovery metadata, terminology artifacts, and bounded clinical data according to policy. It must not become an independent authorization authority and must never extend expired or revoked authorization. Sensitive cross-jurisdiction writes and high-risk reads must fail closed when policy cannot be evaluated.

Event	Required behavior
Gateway unavailable	Return explicit partial response; identify unavailable source; show last refresh only if a permitted cache exists
Authentication service degraded	Validate already-issued, unexpired tokens according to policy; do not grant access beyond token validity
Identity uncertainty	Do not retrieve or merge sensitive records automatically; route for adjudication
Terminology validation failure	Reject or quarantine invalid inbound data; return actionable OperationOutcome
Consent policy unavailable	Fail closed for sensitive cross-jurisdiction access unless an approved emergency pathway applies

9. Clinical Safety and Experience

9.1 Clinical safety requirements

- Perform a clinical safety hazard analysis before pilot deployment.
- Show source, freshness, verification state, and conflicts for medications, allergies, and patient summaries.
- Clearly distinguish absent, unknown, negative, not performed, historical, and current information.
- Require human review for uncertain identity matches and clinically significant reconciliation conflicts.
- Design alert thresholds to prevent alert fatigue; do not create opaque AI-derived alerts in v1.
- Provide documented downtime and partial-data workflows for clinicians.
- Conduct usability testing with physicians, nurses, pharmacists, and health information professionals.

9.2 Accessibility and language

The clinician-facing and future patient-facing experiences must include accessibility requirements, clear clinical status indicators, and French-language support where applicable. Interfaces must not rely on colour alone to communicate high-risk or stale information.

10. Testing, Conformance, and Delivery

10.1 Expanded test strategy

Test category	Added scope
Gateway contracts	Ontario-to-BC and BC-to-Ontario contract tests; schema, profile, auth, rate-limit, timeout, and error semantics
Identity safety	False positive/negative evaluation, demographic variation, candidate review, merge/unmerge, and correction tests
Consent/privacy	Consent withdrawal, restricted records, break-glass, unauthorized access, and PHI-leakage tests
FHIR/terminology	Pinned profile validation, terminology bindings, version upgrade regression, malformed resources, and OperationOutcome quality
Resilience	Partial responses, duplicate submissions, idempotency, retry boundaries, chaos tests, backup restoration, disaster recovery
Clinical usability	Medication/allergy reconciliation, emergency access, stale-data comprehension, clinician workflow, accessibility, and French-language tests
Performance	Separate local-read, write, search, and remote-summary targets with p50/p95/p99, payload size, error rate, and gateway latency

10.2 CI/CD quality gates

- Unit, integration, contract, and security tests must pass.
- FHIR profile and terminology validation must pass against pinned packages.
- Dependency, secret, container, and infrastructure scans must meet the approved risk threshold.
- Database migrations require review and rollback strategy.

- Production deploys require environment protection, approval, artifact provenance, and rollback verification.
- Release notes must identify changed profiles, terminology versions, APIs, privacy impact, and compatibility implications.

10.3 Revised delivery roadmap

Stage	Primary output
0. Discovery and governance	Jurisdictional requirements, privacy roles, gateway inventory, clinical workflow discovery, data-sharing approach
1. Standards baseline	Pinned PS-CA, CA Core+, CACDI, terminology packages, conformance plan
2. Identity and authorization	Identity service, consent/policy engine, practitioner and organization model, break-glass design
3. Core FHIR platform	Versioned FHIR resources, provenance, audit, summary generation, terminology validation
4. Ontario pilot	Controlled local integration and clinical workflow validation
5. BC federation	Gateway adapter, authenticated exchange, partial-response handling, cross-jurisdiction testing
6. Readiness	Privacy/security/safety assessments, resilience, DR, conformance event, operational acceptance
7. Limited production pilot	Monitoring, clinician support, benefits measurement, iterative remediation
8. Expansion	Additional jurisdictions/domains, patient access, and carefully governed non-autonomous AI

11. Operations, Adoption, and Benefits

11.1 Production operations

- High-availability application, authentication, database, and network design.
- Private networking, managed database backups, key management, certificate lifecycle, and infrastructure as code.
- Defined recovery point and recovery time objectives by service and data class.
- 24/7 on-call model or explicitly agreed service-hours model; clinical, privacy, and cybersecurity escalation routes.
- Gateway health dashboard, service status, incident severity definitions, post-incident review, maintenance process, and change advisory process.
- Version compatibility and deprecation policy for provincial adapters, FHIR profiles, and terminology packages.

11.2 Benefits realization metrics

Metric area	Example measure
Clinical access	Percentage of eligible emergency encounters with a successfully retrieved, validated patient summary
Data quality	Required-field completeness, terminology validation rate, provenance completeness, and freshness distribution
Workflow	Time to retrieve external summary, fax volume, manual transcription effort, clinician satisfaction
Safety	Medication discrepancy rate, allergy-information availability, identity-match review outcomes
Reliability	Gateway success, partial-response rate, latency, availability, incident frequency
Privacy	Unauthorized access incidents, break-glass review completion, audit completeness
Adoption and equity	Active organizations and users; results by region, rural/remote service context, language, and population group where appropriate

12. Responsible AI Extension

AI is not a substitute for structured data quality, clinical provenance, consent controls, or human clinical judgment. Version 2.0 AI capabilities must remain non-autonomous and must not make unreviewed diagnostic, prescribing, or triage decisions.

Required AI controls

- Define intended use, prohibited use, user population, and human-review requirements for every model.
- Complete a PHI-processing, vendor, hosting, residency, retention, and subcontractor assessment before any external AI service processes health data.
- Prefer deterministic validation and human-reviewed terminology-mapping assistance before generative clinical functions.
- Version models, prompts, retrieval sources, policies, and output templates; log decisions without leaking unnecessary PHI.
- Evaluate accuracy, bias, equity, hallucination risk, prompt injection, drift, usability, and clinical safety.
- Implement output validation, clinician override, kill switch, rollback, and periodic revalidation.

Recommended AI sequencing

Priority	Capability	Reason
1	Data-quality and terminology mapping suggestions with human approval	Improves structured exchange without making clinical decisions
2	Patient-summary drafting with source-linked citations and clinician review	Reduces synthesis burden while preserving provenance
3	Identity-match candidate ranking with mandatory human adjudication	Assists review but never merges records autonomously
4	Rules-based drug/allergy safety checks	Auditable and clinically governed before LLM-based alerts
5	Later clinical decision support	Only after validation, governance, and safety evidence are established

13. Required Changes to Original SDLC

Original SDLC section	Required amendment
1.2 Problem statement	Replace “single source of truth” wording with “trusted, provenance-preserving federated longitudinal view.” Add identity, consent, terminology, governance, and workflow root causes.
2.1 Functional requirements	Add Consent, Provenance, AuditEvent, Practitioner, PractitionerRole, Organization, Gateway Registry, identity adjudication, partial responses, correction workflows, and terminology operations.
2.2 Non-functional requirements	Add privacy, resilience, RPO/RTO, observability, accessibility, data-quality, conformance, and source-freshness SLOs.
3.1 Architecture	Add policy engine, identity service, terminology service, gateway registry/adapters, provenance store, monitoring, key management, and trust layer.
3.2 Database	Replace simple clinical tables with hybrid canonical FHIR JSONB + indexed projections, resource history, identifiers, consent, provenance, terminology, source records, and merge history.
3.3 APIs	Add resource history, conditional operations, OperationOutcome, Consent, Provenance, AuditEvent, DocumentReference, DiagnosticReport, medication subtypes, care context, and gateway capability APIs.
4.3 Sprint plan	Reframe 16 weeks as prototype-only. Add discovery/governance, standards, identity/consent, terminology, pilot, conformance, safety, and operations stages.
5 Testing	Add contract, conformance, terminology, identity, privacy, resilience, clinical usability, DR, accessibility, and bilingual tests.
6 Deployment	Separate local docker-compose from production. Add HA, private networking, secrets/key vault, managed backup, IaC, image signing, scanning, monitoring, and DR.
7 AI roadmap	Remove unsupported “self-hosted Claude/GPT-4” wording; add PHI vendor assessment, human review, model governance, and non-autonomous use restrictions.
8 Risks	Add consent-policy failure, stale-cache clinical risk, terminology drift, gateway trust failure, data quality/provenance failure, ransomware/DR, operational adoption, and equity risks.

14. Additional Risk Register

Risk	Likelihood	Impact	Required mitigation
Consent or policy mismatch across jurisdictions	Medium	Critical	Policy-as-code, legal review, PIA, jurisdiction-specific adapter rules, fail-closed controls
Stale or partial clinical data shown as complete	Medium	Critical	Freshness indicators, source status, bounded cache, partial-response UI, clinical safety validation
False patient match	Medium	Critical	Tiered matching, conservative thresholds, adjudication, immutable decision audit, no silent merge
Terminology mapping changes meaning	Medium	High	Versioned terminology, source code retention, validation, clinical review, regression testing
Gateway trust or certificate failure	Medium	High	Mutual TLS, certificate rotation, trust registry, monitoring, incident procedures
PHI leakage through logs or AI tooling	Medium	Critical	Data minimization, log redaction, DLP, isolated tooling, security gates, vendor assessment
Ransomware or disaster recovery failure	Medium	Critical	Immutable backups, restore drills, segmented access, incident response, RPO/RTO testing
Low clinician adoption	Medium	High	Co-design, workflow pilot, training, support, outcome measures, minimize duplicate entry
Equity/language/accessibility gap	Medium	High	Accessibility and bilingual requirements, representative testing, patient advisory review

15. Approval and Next Steps

Before implementation proceeds beyond a prototype, the project sponsor should approve this addendum and establish the following named accountabilities: executive sponsor; product owner; clinical safety officer; privacy officer; security officer; interoperability architect; terminology lead; identity-management lead; provincial gateway owners; and patient/Indigenous engagement leads.

Immediate next actions

- Pin the PS-CA, CA Core+, CACDI, FHIR, and terminology-version baseline.
- Run Ontario and BC legal/privacy discovery and identify data custodians, service providers, gateway owners, and disclosure pathways.
- Create the formal patient identity and consent architecture before building interprovincial query functionality.
- Create a gateway capability inventory and contract-test harness before claiming provincial integration.
- Replace the simplified database model with a canonical FHIR-resource and provenance design.
- Revise the sprint plan into a prototype phase plus a separately governed production-readiness phase.
- Conduct clinician workflow and safety discovery focused on emergency, medication reconciliation, laboratory, and diagnostic-report use cases.

This revised SDLC provides the missing foundation for safely recognizing and addressing the real Canadian interoperability problem: reliable, governed, semantically consistent, and clinically usable movement of health information across jurisdictional boundaries.